FR-12 – Step 2: Identify equivalence classes for each input & output

Input: the variables and decisions (D1–D8) in `FR-12_1_variables.md`. Method: lecture S04 *Domain Testing*, step 2.

Authorship: the classes were generated by **ChatGPT** from the step 1 file, the lecture guideline and an example step 2 file. They were then **reviewed by the tester and restructured with Claude**: duplicates merged, untestable classes removed, V/I values normalised, and outputs linked to class IDs. No new test ideas were added in the restructuring. The full list of changes is in *Review changes* at the end.

Guidelines applied (S04, slides 8–11)

Condition kind	Rule	Example in this feature
Set	1 valid class per element (if handled differently) + 1 invalid class	Endpoint group, HTTP method, public endpoints, stored token
Must be	1 valid class + 1 invalid class	Header present, `Bearer` scheme, token unmodified, role = admin, no `role` in profile update
Range (date/time)	1 valid class + invalid class(es)	Token age (recorded only, D4)
Split	Split a class when its members may not be handled the same way	Scheme variants, malformed vs altered token, deleted vs demoted owner

Legend: V = valid, I = invalid, TBD = expected result recorded at execution. "Tester decision" = the spec is silent; the expected result was chosen by the tester (see the decision log). For IN_09 (endpoint) and IN_10 (method), every listed value is a legitimate request (**V**); which combinations are protected is checked through the outputs and in step 3. Representative values are **not** chosen here; that is step 3.

Input equivalence classes

FR-12_IN_01 – Account role used to log in to the admin web app

Class ID	Condition (guideline)	Equivalence class	V / I	Source
FR-12_EC_01	C1 Role must be admin (must be)	Account role is `admin`	V	Spec
FR-12_EC_02	C1 Role must be admin (must be)	Account role is `user`	I	Spec

FR-12_IN_02 – Credentials at the admin web login

Class ID	Condition (guideline)	Equivalence class	V / I	Source
FR-12_EC_03	C1 Correct pair (must be)	Correct email and password of an existing account	V	Assumption (FR-02)
FR-12_EC_04	C1 Correct pair (must be)	Existing email, wrong password	I	Assumption (FR-02)
FR-12_EC_05	C1 (split)	Email or password empty	I	Assumption

Class ID	Condition (guideline)	Equivalence class	V / I	Source
FR-12_EC_06	C1 (split)	Email of an account that does not exist	I	Assumption

FR-12_IN_03 – `Authorization` header on a protected API request

Class ID	Condition (guideline)	Equivalence class	V / I	Source
FR-12_EC_07	C1 Present (must be)	Header present	V	Spec
FR-12_EC_08	C1 Present (must be)	Header missing	I	Spec (SEC-02)

FR-12_IN_04 – Header scheme

Class ID	Condition (guideline)	Equivalence class	V / I	Source
FR-12_EC_09	C1 Exactly `Bearer <token>` (must be)	`Bearer` followed by a token	V	Spec + D6
FR-12_EC_10	C1 (split)	Lower- or mixed-case `bearer`	I	D6
FR-12_EC_11	C1 (split)	Token without any scheme	I	D6
FR-12_EC_12	C1 (split)	A different scheme	I	D6
FR-12_EC_13	C1 (split)	`Bearer` with an empty token part	I	Assumption

FR-12_IN_05 – Token integrity

Class ID	Condition (guideline)	Equivalence class	V / I	Source
FR-12_EC_14	C1 Issued and unmodified (must be)	Token issued by the server, unchanged	V	Spec
FR-12_EC_15	C1 (split)	Not a token at all (random or malformed text)	I	Spec (SEC-02)
FR-12_EC_16	C1 (split)	Token-shaped, but altered after issue	I	Spec (SEC-02)

FR-12_IN_06 – `role` claim in the token

Class ID	Condition (guideline)	Equivalence class	V / I	Source
FR-12_EC_17	C1 Role = admin (must be)	Valid token with role `admin`	V	Spec (SEC-03)
FR-12_EC_18	C1 Role = admin (must be)	Valid token with role `user`	I	Spec (SEC-03)

FR-12_IN_07 – Token age

Class ID	Condition (guideline)	Equivalence class	V / I	Source
FR-12_EC_19	C1 Not expired (range)	Freshly issued token	V	Spec
FR-12_EC_20	C1 Not expired (range)	Old token, expired if expiry exists	TBD	D4 (record only)

FR-12_IN_08 – Token owner's current account state

Class ID	Condition (guideline)	Equivalence class	V / I	Source
FR-12_EC_21	C1 Owner unchanged (must be)	Owner still exists and is still admin	V	Spec
FR-12_EC_22	C1 (split)	Owner deleted after the token was issued	I	D5 + D9 (expect 404)
FR-12_EC_23	C1 (split)	Owner demoted from admin after the token was issued	I	D5 + D9 (expect 403)

FR-12_IN_09 – Protected endpoint path

Class ID	Condition (guideline)	Equivalence class	V / I	Source
FR-12_EC_24	C1 Endpoint group (set)	`/api/admin/users`, `/api/admin/orders`, `/api/admin/import-products`	V	Spec
FR-12_EC_25	C1 (set)	`/api/admin/coupons`	V	Spec
FR-12_EC_26	C1 (set)	`/api/products` (write methods)	V	Spec
FR-12_EC_27	C1 (set)	`/api/categories` (write methods)	V	Spec
FR-12_EC_28	C1 (set)	`/api/coupons` (writes per D1, `GET` per D2)	V	D1 + D2
FR-12_EC_29	C1 (set, out of set)	Admin path that does not exist	I	D8

FR-12_IN_10 – HTTP method

Class ID	Condition (guideline)	Equivalence class	V / I	Source
FR-12_EC_30	C1 Method (set)	`GET`	V	Spec
FR-12_EC_31	C1 (set)	`POST`	V	Spec
FR-12_EC_32	C1 (set)	`PUT`	V	Spec
FR-12_EC_33	C1 (set)	`DELETE`	V	Spec
FR-12_EC_34	C1 (set, out of set)	Any other method	I	Assumption

Which method is protected on which path: admin paths, all methods; products and categories, `POST/PUT/DELETE` only; `/api/coupons`, all methods (D2).

FR-12_IN_11 – Public read endpoint (control group)

Class ID	Condition (guideline)	Equivalence class	V / I	Source
FR-12_EC_35	C1 Public endpoint (set)	`GET /api/products`	V	Spec
FR-12_EC_36	C1 (set)	`GET /api/products/:id`	V	Spec
FR-12_EC_37	C1 (set)	`GET /api/categories`	V	Spec

No invalid class: a protected endpoint is not a value of this variable; it is covered by IN_09.

FR-12_IN_12 – Admin web page opened directly

Class ID	Condition (guideline)	Equivalence class	V / I	Source
FR-12_EC_38	C1 Logged in (must be)	Logged in as admin	V	Assumption
FR-12_EC_39	C1 Logged in (must be)	Not logged in (no token stored)	I	Assumption

FR-12_IN_13 – Token stored in the admin web app's browser storage

Class ID	Condition (guideline)	Equivalence class	V / I	Source
FR-12_EC_40	C1 Stored token (set)	Admin token	V	Assumption
FR-12_EC_41	C1 (set)	User token	I	Assumption
FR-12_EC_42	C1 (set)	Random or malformed text	I	Assumption

FR-12_IN_14 – `role` field sent in `PUT /api/users/me`

Class ID	Condition (guideline)	Equivalence class	V / I	Source
FR-12_EC_43	C1 No `role` field (must be)	Profile update without a `role` field	V	Spec (SEC-06, FR-04)
FR-12_EC_44	C1 (split)	`role` set to `admin`	I	Spec (SEC-06, FR-04)
FR-12_EC_45	C1 (split)	`role` set to any other value	I	Spec (SEC-06, FR-04)

Output equivalence classes

Class ID	Output variable	Equivalence class	Triggered by	Source
FR-12_EC_46	OUT_01 Protected API, valid admin token	Request performed (HTTP 2xx)	EC_07 + 09 + 14 + 17 + 19 + 21 on EC_24–28	Spec
FR-12_EC_47	OUT_02 Protected API without a valid token	Rejected, HTTP 401	EC_08, 10, 11, 12, 13, 15, 16 (EC_20 if expiry exists)	Spec (SEC-02) + D3
FR-12_EC_48	OUT_03 Protected API, token not allowed	Rejected: 403 for wrong or demoted role; 404 for a deleted owner; 403 or 404 for a non-existent admin path	EC_18, 22, 23, 29	Spec (SEC-03) + D3, D8, D9
FR-12_EC_49	OUT_04 Data after a rejected request	Unchanged	Any rejected request on EC_25–28 with EC_31–33	Spec (implied)
FR-12_EC_50	OUT_05 Body of a rejected request	No protected data, no internal details; for EC_34 any 4xx, never 2xx	Every rejected request, EC_34	Assumption
FR-12_EC_51	OUT_06 Public endpoint without a token	Allowed (HTTP 200)	EC_35, 36, 37	Spec
FR-12_EC_52	OUT_07 Admin login, admin account	Dashboard shown	EC_01 + EC_03	Spec
FR-12_EC_53	OUT_08 Admin login, user account	Refused with a message; no admin page	EC_02 + EC_03	Spec + Assumption (wording)

Class ID	Output variable	Equivalence class	Triggered by	Source
FR-12_EC_54	OUT_09 Admin login, wrong credentials	Error message; no admin page	EC_04, 05, 06	Assumption
FR-12_EC_55	OUT_10 Admin page without login	Redirected to admin login; no data	EC_39	Assumption
FR-12_EC_56	OUT_11 Admin app with a bad stored token	No admin data shown	EC_41, 42	Assumption
FR-12_EC_57	OUT_12 Role after profile update	Unchanged	EC_43, 44, 45	Spec (SEC-06)

Summary

	Count
Valid input classes	23
Invalid input classes	21
TBD input classes	1 (EC_20)
Output classes	12
Total	**57**

ChatGPT's original draft had 67 classes: 8 were removed and 2 pairs merged (67 − 8 − 2 = 57); see below.

Decision log

D1–D8 are carried over from step 1. New in step 2:

#	Question	Decision
D9	Status code when the token's owner was deleted or demoted (D5)	**Deleted: 404** (tester decision: the user resource no longer exists). **Demoted: 403**, following D3, because the account exists but is no longer admin.
D10	Classes no black-box tester can reach	**Removed** (see review changes); recorded in the AI gap analysis.

Review changes (ChatGPT draft → this file)

ChatGPT class(es)	Change	Reason
All	V / I column normalised to V, I or TBD	Draft used phrases ("I for admin access", "V / TBD", "Protected; admin token required"); EC_27–42 had no V/I value.
All outputs	"Triggered by" rewritten as class IDs	Needed for the step 3 coverage check.
EC_03	**Removed**	An account with a missing or unknown role cannot be created through the app.
EC_04, EC_05	Merged into new EC_03 (correct credentials)	Duplicated the admin/user split already in IN_01.

ChatGPT class(es)	Change	Reason
EC_06	Renamed EC_04, narrowed to "wrong password"	EC_08 (unknown account) is its own class.
EC_17, EC_18	Split cleanly into EC_15 (not a token) and EC_16 (altered token)	"Forged or modified" in EC_17 already contained EC_18.
EC_21	**Removed**	Only the server issues valid tokens, and it only issues `admin` or `user`; unreachable black-box.
EC_22	Now EC_19, V instead of "V / TBD"	A fresh token is simply valid; only the expired case is TBD.
EC_27–32	Methods removed from endpoint classes	Methods belong to IN_10; mixing them duplicated EC_38–40.
EC_31, EC_32	Merged into EC_28 (`/api/coupons` , all methods)	Same path; D1 and D2 both apply to it.
EC_33, EC_34, EC_41	**Removed**	Duplicated the public endpoints in IN_11.
EC_36	**Removed**	"Other endpoints not in scope": not testable and outside FR-12.
EC_37–40	Simplified to one class per method (EC_30–33)	Endpoint-dependence is handled by IN_09 and the outputs.
EC_46	**Removed**	An expected outcome, not a value of IN_11; covered by EC_47 and EC_48.
EC_52	**Removed** (merged into EC_39)	"No token stored" = "not logged in".
EC_53, EC_54	Changed from V to **I** (now EC_44, EC_45)	Sending `role` is the input the system must ignore; under the must-be rule, "no role field" (EC_43) is the valid class.